

Plan de continuité et de reprise d'activité

PCA / PRA — Attaque par rançongiciel MIRAGE (groupe SIROCCO)

Cellule Continuité d'activité

Équipe de rédaction

BEN CHEICH Hamza

EL HADRI Safae

CHAMLI Romayssaa

ATOUAHRI Malak

KOUJI Mohammed

ZEKRI Taha

Sommaire

1. Objet, périmètre et définitions
2. Situation et hypothèses de travail
3. Analyse d'impact : activités et actifs critiques
4. Plan de continuité d'activité (PCA)
5. Plan de reprise d'activité (PRA)
6. Points à confirmer

En une phrase. Le PCA dit comment AtlasGrid continue à fonctionner *pendant* l'attaque (protéger, couper, travailler en mode dégradé) ; le PRA dit comment elle redémarre *après* (dans quel ordre, à partir de quelles sauvegardes, avec quels contrôles). Priorité de ce document : le PCA.

1. Objet, périmètre et définitions

Ce plan organise la réponse de la cellule Continuité d'activité à l'attaque par rançongiciel qui touche AtlasGrid, opérateur d'énergie basé à Casablanca (production et distribution, environ 1 200 salariés, clients grands comptes et collectivités liés par des engagements de disponibilité). Il couvre le SI de gestion, les interfaces avec le prestataire OasisNet et la protection du réseau industriel (OT).

Terme	Définition utilisée dans ce plan
PCA	Ensemble des mesures permettant de maintenir les activités essentielles pendant la crise, au besoin en mode dégradé.
PRA	Ensemble des mesures permettant de restaurer le SI et de revenir au fonctionnement normal après la crise.
DMIA	Durée maximale d'interruption admissible : temps au-delà duquel l'arrêt d'une activité devient inacceptable (équivalent RTO).
PDMA	Perte de données maximale admissible : quantité de données qu'on accepte de perdre, exprimée en temps (équivalent RPO).

2. Situation et hypothèses de travail

Conformément à la règle « ce que l'on sait ≠ ce que l'on croit », la situation est séparée en faits établis et hypothèses à confirmer.

Statut	Élément	Conséquence pour la continuité
Fait	Rançongiciel MIRAGE attribué au groupe SIROCCO ; symptômes : lenteurs, fichiers renommés.	Risque de chiffrement étendu des serveurs Windows / SQL Server.
Fait	OasisNet signale une maintenance « mal terminée » ce week-end, sans détail ni ticket.	Sauvegardes en ligne et accès VPN d'OasisNet considérés comme non fiables jusqu'à preuve du contraire.
Fait	Le poste FIN-112 est identifié comme premier poste touché (EDR désactivé avant chiffrement).	Poste à isoler ; comptes utilisés sur ce poste à considérer comme compromis.
Hypothèse	L'annuaire AD est compromis ou exposé.	Aucune restauration applicative avant reconstruction d'un AD sain.

Statut	Élément	Conséquence pour la continuité
Hypothèse	Le réseau OT est réellement isolé du SI.	À vérifier en priorité ; tant que non prouvé, protéger l'OT comme s'il était exposé.
Hypothèse	Les jobs Veeam récents sont intègres.	Deux scénarios de reprise prévus (voir 5.4).

3. Analyse d'impact : activités et actifs critiques

L'échelle retenue comporte quatre niveaux : **Vital** (aucun mode dégradé acceptable ou condition de toute reprise), **Critique** (dégâts sérieux sous 24 à 48 h), **Important** (mode dégradé tenable plusieurs jours), **Secondaire** (inconfort sans impact sur la mission). Tout n'est volontairement pas vital.

Actif	Serveur(s)	Niveau	DMIA	PDMA	Justification
Supervision industrielle	SCADA-HMI-*	Vital (mission)	0 (ne doit pas s'arrêter)	N/A	Pilote la production et la distribution ; sécurité des personnes ; régulateur.
Annuaire	DC-01, DC-02	Vital (socle)	24 h (après reconstruction)	24 h	Tout s'y authentifie ; sa compromission donne le contrôle du SI.
Sauvegardes	VBR-01, BKP-01/02, LTO-9	Vital (reprise)	À préserver	—	Seul moyen de restaurer sans payer ; copie hors ligne seulement trimestrielle.
Facturation + portail	FACT-02, WEB-CLI-01	Critique	48 h	24 h	Chaîne de revenu ; trésorerie ; relation grands comptes.
VPN d'administration	VPN-GW	Critique	Restreint	—	Nécessaire à OasisNet mais vecteur d'entrée possible.
Antivirus / EDR	Console Defender	Critique	4 h	—	Seule visibilité sur la propagation.
Messagerie + téléphonie	MSG-01, IPBX-01	Critique en crise	Palliatif immédiat	24 h	Coordination et communication externe ; remplaçables par mobiles.
ERP	ERP-APP-01, ERP-DB-01	Important	3 à 5 jours	24 h	Achats, stocks, compta ; procédure papier possible.
Paie	PAIE-01	Important*	Selon échéance	1 mois	Devient critique à J-5 du versement des salaires.
Serveurs de fichiers	FILER-RBT-02, FILER-CASA-01	Important	3 jours	24 h	Cible du chiffrage ; documents métiers.
Intranet, site public	INTRA-01, hébergeur externe	Secondaire	Plusieurs jours	1 semaine	Pas d'impact sur la mission ; le site public peut servir de canal d'information.

* Niveau variable dans le temps. Les DMIA sont des propositions de la cellule, à valider par la Direction et les métiers.

Écart majeur identifié. Si les sauvegardes Veeam sont inutilisables, la seule copie saine est la bande LTO-9 trimestrielle : la PDMA réelle peut alors atteindre **3 mois**, très au-delà des 24 h visées. Cet écart doit être porté à la connaissance de la Direction dès maintenant.

4. Plan de continuité d'activité (PCA)

4.1 Déclenchement et gouvernance

Le PCA est déclenché par la Direction de crise sur proposition de la cellule Continuité dès que l'un des critères suivants est rempli : chiffrage confirmé sur au moins un serveur, compromission suspectée d'un compte à privilèges, indisponibilité d'un actif vital ou critique au-delà de sa DMIA, ou doute sérieux sur l'intégrité des sauvegardes. Tous ces critères sont atteints ou en cours d'évaluation.

- **Décision** : la Direction arbitre ; la cellule Continuité propose, chiffre l'impact et suit l'exécution.
- **Rythme** : point de situation toutes les 2 heures avec SOC, Forensic, Risque/Conformité et Communication.
- **Traçabilité** : chaque décision est horodatée dans la main courante (qui, quoi, pourquoi, heure).

4.2 Mesures conservatoires immédiates (H0 à H+4)

Objectif : empêcher l'attaque de s'étendre aux actifs vitaux avant toute autre action. Principe : **protéger avant de restaurer**.

#	Mesure	Actif protégé	Pourquoi	Qui
1	Vérifier et renforcer l'isolement OT : couper tout lien physique ou logique avec le SI, suspendre les accès distants vers l'OT, passer en conduite locale renforcée.	SCADA	Actif vital par sa mission ; l'isolement est déclaré mais non prouvé.	Continuité + équipe OT
2	Isoler les sauvegardes : déconnecter VBR-01 et BKP-01/02 du réseau, geler toute suppression ou purge, mettre les bandes LTO-9 sous clé au site secondaire.	Sauvegardes	Les attaquants détruisent les sauvegardes avant de chiffrer ; les LTO sont peut-être le dernier recours.	Continuité + DSI
3	Restreindre le VPN d'administration : suspendre les comptes OasisNet, n'autoriser que des interventions validées et accompagnées.	VPN-GW	Incident non expliqué chez OasisNet ; accès à forts privilèges.	DSI, sur décision Direction
4	Isoler du réseau le poste FIN-112 sans l'éteindre (préservation de la mémoire pour l'enquête).	Postes / SI	Stopper la propagation tout en gardant les preuves.	SOC + Forensic
5	Préserver les preuves : journaux VPN, EDR, pare-feu, Veeam ; ne rien réinstaller sans accord Forensic.	Enquête, assurance	Obligation de préservation de la police cyber.	Forensic
6	Ouvrir un canal de communication hors bande : téléphones mobiles, liste de contacts imprimée, messagerie externe de secours.	Coordination	Exchange et IPBX reposent sur le SI attaqué.	Continuité + Communication

4.3 Modes dégradés par activité

Pour chaque activité essentielle, la cellule définit comment continuer sans l'outil habituel, combien de temps c'est tenable, et qui en est responsable côté métier.

Activité	Système indisponible	Mode dégradé	Tenable	Responsable
Conduite du réseau électrique	SCADA (si doute)	Conduite locale par les opérateurs, astreintes renforcées, consignes d'exploitation papier, interdiction de toute connexion externe.	Tant que l'OT reste sain	Direction de l'exploitation

Activité	Système indisponible	Mode dégradé	Tenable	Responsable
Facturation clients	FACT-02, WEB-CLI-01	Suspension temporaire des émissions et relances ; facturation manuelle des grands comptes prioritaires si nécessaire ; page d'indisponibilité et numéro dédié sur le portail.	48 h, puis manuel	Direction financière
Achats et stocks	ERP	Bons de commande papier numérotés ; inventaire manuel des pièces critiques de maintenance réseau ; saisie a posteriori.	3 à 5 jours	Achats / logistique
Paie	PAIE-01	Reconduction de la paie du mois précédent via la banque ; régularisation après reprise ; communication aux salariés.	Jusqu'à l'échéance	DRH
Coordination interne	MSG-01, IPBX-01, INTRA-01	Téléphones mobiles, groupes de messagerie de secours, points physiques réguliers, annuaire de crise imprimé.	Immédiat	Cellule Continuité
Documents métiers	Serveurs de fichiers	Utilisation des versions imprimées ou hors ligne des procédures critiques, contrats et contacts.	3 jours	Chaque direction

4.4 Communication liée à la continuité

La cellule Continuité fournit les faits ; la cellule Communication rédige ; la Direction valide avant tout envoi.

Destinataire	Message clé de continuité	Canal	Moment
Salariés	Consignes : ne pas rallumer les postes isolés, utiliser les canaux de secours, procédures dégradées applicables.	SMS, affichage, managers	Dès H+2
Clients grands comptes	La fourniture d'énergie est maintenue (si confirmé) ; la facturation et le portail sont temporairement perturbés ; interlocuteur dédié.	Téléphone, e-mail de secours	Avant l'échéance SLA
OasisNet	Demande écrite d'informations détaillées, gel des opérations sur les sauvegardes, restriction des accès.	E-mail + appel	Immédiat
Assureur cyber	Déclaration du sinistre, mesures de préservation des preuves engagées.	Selon la police	Dans les délais contractuels
Autorité de régulation	Notification d'incident majeur selon le cadre applicable (loi 05-20) ; délais et contenu à confirmer par Risque/Conformité.	Canal officiel	Selon la réglementation

4.5 Critères de sortie du mode dégradé

- L'attaquant est considéré comme expulsé (confirmation Forensic et SOC).
- Un annuaire sain est reconstruit et les comptes à privilèges sont réinitialisés.
- Les sauvegardes utilisées pour la reprise sont vérifiées comme antérieures à la compromission et non altérées.
- La Direction valide le passage au PRA, système par système.

5. Plan de reprise d'activité (PRA)

5.1 Principes de reprise

- **Pas de reprise sans feu vert Forensic** : restaurer trop tôt réinstalle l'attaquant.
- **Reconstruire plutôt que nettoyer** les systèmes socles (annuaire en particulier).
- **Restaurer depuis une sauvegarde antérieure à la date de compromission**, date établie par le Forensic.
- **Reprise progressive** dans un réseau cloisonné, puis ouverture contrôlée.

5.2 Ordre de reprise

Phase	Délai visé	Systèmes	Objectif	Condition de passage
0. Préparation	H0 à J+1	Environnement de reconstruction isolé, sauvegardes	Disposer d'une zone saine et d'une sauvegarde vérifiée.	Test de restauration réussi hors réseau de production.
1. Socle	J+1 à J+2	DC-01, DC-02, console EDR	Annuaire sain, EDR actif partout.	Réinitialisation de tous les mots de passe à privilèges et des comptes de service ; EDR opérationnel.
2. Communication	J+2	MSG-01, IPBX-01	Rendre à l'entreprise ses outils de coordination.	Serveurs restaurés, scannés et surveillés.
3. Revenu	J+2 à J+3	ERP-DB-01, ERP-APP-01, FACT-02, puis WEB-CLI-01	Relancer la chaîne de facturation.	Cohérence des données vérifiée par la finance ; portail remis en ligne en dernier.
4. Métiers	J+3 à J+5	FILER-RBT-02, FILER-CASA-01, PAIE-01	Retour des documents et de la paie.	Paie priorisée si l'échéance est proche.
5. Secondaires	J+5 et après	INTRA-01, postes utilisateurs	Retour complet au fonctionnement normal.	Postes réinstallés ou contrôlés avant reconnexion.
6. Tiers	Après validation	VPN-GW / accès OasisNet	Rétablir l'infogérance.	Explications écrites d'OasisNet, comptes renouvelés, authentification forte, accès journalisés.

5.3 Contrôles avant remise en service d'un système

- Sauvegarde source antérieure à la compromission et intègre.
- Système restauré dans un réseau isolé, analysé par l'EDR, sans indicateur de compromission connu.
- Correctifs de sécurité appliqués, comptes locaux et de service renouvelés.
- Test fonctionnel validé par le responsable métier.
- Décision de remise en service horodatée et visée dans la main courante.

5.4 Deux scénarios selon l'état des sauvegardes

Scénario	Condition	Perte de données	Conséquences et actions
A — Veeam sain	Les jobs récents sont intacts et antérieurs à la compromission.	Environ 24 h	Reprise selon le calendrier 5.2 ; ressaisie limitée des opérations du dernier jour à partir des traces papier.

Scénario	Condition	Perte de données	Conséquences et actions
B — Veeam compromis	Sauvegardes en ligne chiffrées, supprimées ou douteuses.	Jusqu'à 3 mois (dernière bande LTO-9)	Reprise depuis LTO ; reconstitution des données à partir des documents papier, e-mails clients, relevés bancaires ; délais du PRA allongés ; information de la Direction, de l'assureur et des clients.

6. Points à confirmer

- Étanchéité réelle du réseau OT (comptes partagés, accès OasisNet, supports amovibles).
- Intégrité et date des dernières sauvegardes Veeam réussies.
- Nature exacte de l'incident OasisNet et comptes utilisés pendant le week-end.
- Lien entre l'ERP et FACT-02 (alimentation des données de facturation).
- Périmètre exact de l'engagement de disponibilité de 99,5 % (énergie ou services informatiques).
- Date de la prochaine paie.